

>\_ LECTURE 12

# Reconnaissance with AI

Asset discovery, subdomain enumeration, content discovery, OSINT — and using AI to parse, clean, and prioritise the noise.

---

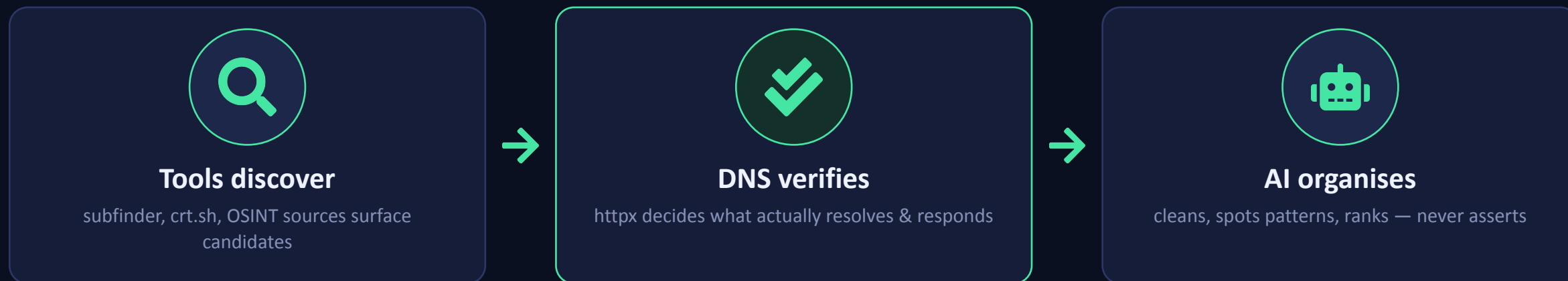
Ethical Hacking with AI — From Foundations to Exploitation

Instructor **Ibrahim Auwal**



# First phase, first discipline

Recon is your first offensive phase — and where last lecture's discipline earns its keep. The division of labour never changes:



**You can't attack an attack surface you can't see.** Recon makes the invisible visible.

# The attack surface

Recon builds a **map of everything an organisation exposes**.

A beginner sees one website. A recon-minded hacker sees an organisation: dozens of domains, hundreds of subdomains, forgotten servers, exposed dashboards, leaked secrets.

You attack the organisation — **not one URL**.



**Domains** root domains the org owns



**Subdomains** api · dev · staging · admin



**Live hosts** what actually responds



**Services & ports** what's listening



**Technologies** stacks & versions



**OSINT** people · secrets · history

# Three ways to widen the map



## Subdomain enumeration

Find the hostnames

api, dev, staging, admin — the forgotten ones are usually the way in.



## Content discovery

Find paths within a host

Crawl and brute-force for endpoints, files, and hidden admin panels.



## OSINT

Public intel, no scanning

Certificate logs, Shodan, leaked secrets in Git, archived URLs.

# Passive first, then active



## Passive

Query third parties that already hold data about the target. The target's servers never see you.

`cert logs · search engines · DNS · Git · Wayback`

*Quiet, low-risk — always start here.*



## Active

Interact with the target directly — resolve, probe, scan, fingerprint. Far more informative, but it lands on their logs.

`httpx · naabu · katana`

*Needs authorisation — go active only on cleared assets.*

**"Passive" ≠ "legal by default."** Authorisation covers the whole recon phase, not just exploitation.

# Authorised targets only

Organisations sprawl into subsidiaries, vendors, and look-alike domains. It is easy to wander out of scope during recon.

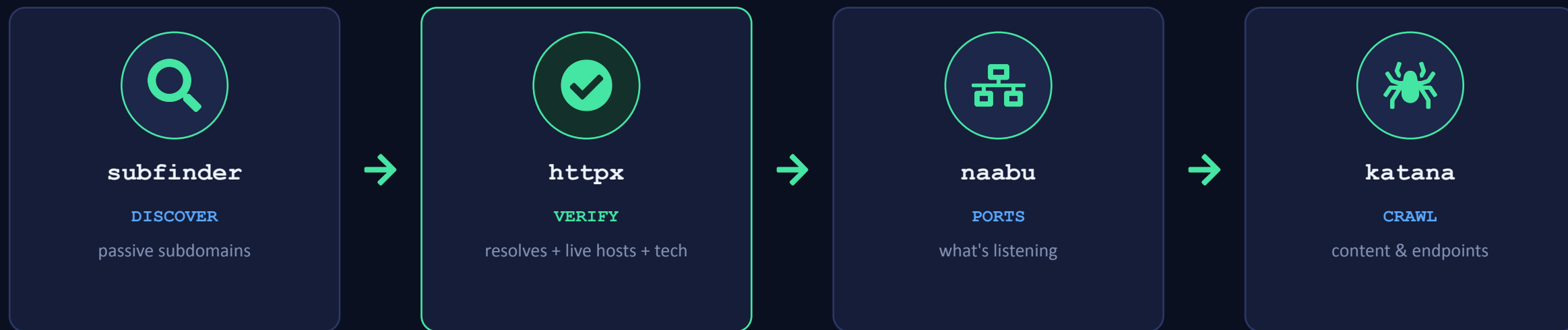


- ✓ Your own domain, an authorised bug-bounty scope, or an instructor-designated target
- ✓ Finding an asset  $\neq$  permission to probe it — confirm scope before going active
- ✓ Recording for a public video? Never point these tools at a random third party

**Same rule as always:** the tool never extends your authorisation. Scope is defined by the engagement.

# One pipeline, four ProjectDiscovery tools

Small tools, each doing one job, piped together. Note where verification sits.



```
$ subfinder -d $T -silent | httpx -silent -json -o httpx.json
```

# From one-liners to a script

1

## One tool

run each bare — see what it does

2

## Pipe them

chain output → input

3

## Script it

arguments, folders, comments

```
recon.sh
```

```
#!/usr/bin/env bash
```

```
set -euo pipefail
```

```
T="$1"; mkdir -p "recon/$T"
```

```
subfinder -d "$T" -silent -o subs.txt # discover
```

```
httpx -l subs.txt -silent -o live.txt # verify + probe
```

```
httpx -l live.txt -silent -json \
```

```
    -o httpx.json # enrich
```

```
naabu -l live.txt -top-ports 100 # ports
```

```
katana -list live.txt -o urls.txt # crawl
```



# Organise — don't discover



## Clean

Merge tool outputs, dedupe, strip wildcards, turn messy JSON into a tidy table.



## Spot patterns

Read the naming scheme: web1/web2 implies web3. Flag dev, staging, admin hosts.



## Prioritise

Rank the top hosts to test first and flag outdated tech worth chasing.

The model never asserts what exists — **it makes sense of what your tools proved.**

# Tools discover. DNS verifies.

Ask an LLM for subdomains and it will **invent plausible ones that don't exist**. It has no live view of DNS.

So every candidate — whether a tool found it or the model suggested it — gets probed before you believe it:

```
$ echo "web3.$T" | httpx -silent
```

**generate** → **test** → **observe** → **refine**, applied to recon.

candidate → probe

api.\$T

live



dev.\$T

live



admin-portal.\$T

invented



web3.\$T

invented



*Two respond. Two the model made up. Only the probe could tell you which.*

# Driving Claude on your recon files

The Claude extension reads the files in your VS Code workspace. [Point it at what recon.sh just wrote.](#)

## CLEAN

Read httpx.json — give me a table of host, status, title, and tech, sorted with the most interesting first.

## PATTERNS

Look at these hostnames. What naming patterns exist, and what subdomains would you guess we haven't found? Which look like dev / staging / admin?

## VERIFY

```
echo the guessed names | httpx -silent ← probe before believing a single one
```

## PRIORITISE

From the verified live hosts, rank the top 5 to test first and flag anything running an outdated version.

# What's worth attacking first



## Forgotten / non-prod hosts

dev, staging, test, old — weaker controls, real data, less monitoring



## Outdated technology

old server, framework, or library versions with known issues



## Exposed management interfaces

admin panels, Jenkins, Grafana, phpMyAdmin, login portals



## Large or unusual surface

many parameters, uploads, APIs, or auth flows to test

Recon ends with a ranked list — **the hit-list for every attack lecture that follows.**

# How the practical runs



## A · Concepts

Recon, attack surface, the vocabulary — the map we're about to build.



## B · Tools & script

Run each ProjectDiscovery tool, then wrap them in recon.sh.



## C · Claude in VS Code

Clean the output, spot patterns, verify, and rank the targets.

Narrate the *why*, not just the keystrokes — and let one AI-guessed host fail to resolve on camera.

# Lab: map an authorised target

In-scope targets only. Passive first; go active only on cleared assets.

**1**

## Passive collect

Gather subdomains from two sources — subfinder and crt.sh. See how they disagree.

**2**

## AI clean

Paste both into Claude: merge, dedupe, strip wildcards, group by function.

**3**

## Verify — the important one

Probe with httpx — it keeps only live hosts. Ask for 10 guessed subs; count how many respond.

**4**

## Prioritise

Feed the verified list back; have Claude rank the top targets and justify each.

**Deliverable** a one-page recon report: verified live hosts, their tech, and a ranked top-5 with a reason each.

# What to carry forward

- ✓ Recon comes first — you can't attack what you can't see.
- ✓ Passive (third parties) before active (resolve, probe, scan).
- ✓ The goal is a map: domains, subdomains, hosts, services, tech, OSINT.
- ✓ Pipeline: subfinder → httpx → naabu → katana.
- ✓ AI cleans, spots patterns, and prioritises — it never discovers.
- ✓ Every candidate gets probed before you believe it.



## The spine

tools discover

DNS verifies

AI organises

>\_ UP NEXT

## Lecture 13

# Broken Access Control

IDOR, privilege escalation, and forced browsing — with AI assistance. The ranked target list you just built becomes the hit-list.

---

Tools discover · DNS verifies · AI organises. Bring the map with you.

